3 Authentication: Who are you?

This chapter covers

- Why authentication is crucial to relationship integrity
- The phases in the identity lifecycle and why enrollment is often the weak link
- How authentication works
- The tradeoffs between authentication strength and usability
- Properties of a good authentication system

On July 15, 2020, Twitter (now known as X) suffered one of its most high-profile security breaches. Attackers hijacked the accounts of major public figures, including Elon Musk and Barack Obama—and even Apple—to hype a cryptocurrency scam. The breach illustrates a fundamental truth about authentication: it's only as secure as its weakest link.

The details of how the breach happened offer important insights. The attackers didn't use brute force to crack passwords or exploit a bug in Twitter's software. Instead, they used social engineering and phishing to trick Twitter employees into giving them legitimate authentication credentials. By calling Twitter's IT help desk and pretending to be colleagues, they convinced employees to reset authentication credentials, giving the attackers access to Twitter's internal administrative tools.

Once inside, the attackers bypassed traditional security controls and took over high-profile accounts. The near-term fallout was that Twitter had to temporarily lock down all verified accounts to stop further exploitation; the long-term consequence was a loss of trust by people with verified accounts and the people who relied on them to be protected from misinformation.

We can learn several lessons about authentication from this disaster:

- Strong authentication isn't just a technical problem but includes process—governance—too. This is a theme we'll touch on over and over in